



Week 04 Task-10

Vulnerability Scanning Basics

CandidateName: Asad Ali

Reference Number: TBS-INT-2026-445

Submission Date: 8/9/2026

Submitted To: TechBiz Security

Table of Contents

Executive Summary	3
Scope	3
Tools Used	3
Target Connectivity verification	3
Vulnerability Scanning using Nmap NSE Scripts	4
TryHackme Room Vulnerability 101	7
Conclusion	8

Executive Summary

The executive summary of this task is that This task provided me practical exposure to the vulnerability-assessment process, combining Nmap Scripting Engine (NSE) scanning with foundational vulnerability-management concepts. The assessment involved identifying potential vulnerabilities using Nmap scripts and learning how discovered weaknesses can be evaluated using severity scores and vulnerability databases such as the Common vulnerabilities and exposure (CVE) ecosystem. The TryHackMe Vulnerability 101 room was also completed to reinforce the concepts of vulnerability identification, scoring, research, and analysis through a practical example. The overall objective was to develop an understanding of how security professionals discover, assess, and research vulnerabilities before any exploitation or remediation activity. All activity is performed on home network no real world system is engaged.

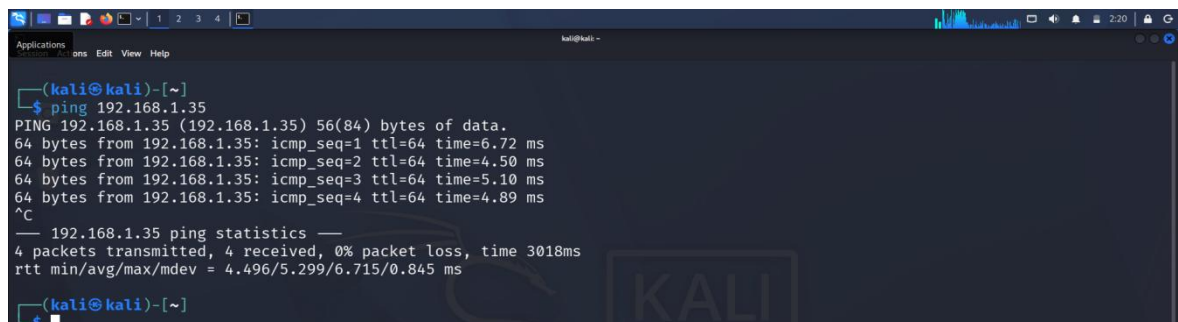
Scope

The scope of this task covered vulnerability scanning and fundamental vulnerability assessment concepts. Nmap Scripting Engine (NSE) was used to identify potential vulnerabilities and security weaknesses in a target environment through automated scanning scripts. In addition, the TryHackMe Vulnerability 101 room was completed to understand vulnerability identification, vulnerability scoring, vulnerability databases, and the general process of researching vulnerabilities. No exploitation or unauthorized access was performed as part of this task.

Tools Used

- Kali Linux (Attacker Machine)
- Nmap (Network scanning Tool)
- Metasploitable2 (Target Machine)

Target Connectivity verification

A screenshot of a Kali Linux terminal window. The terminal shows a command prompt where the user has entered 'ping 192.168.1.35'. The output shows four successful ping responses with varying times (6.72 ms, 4.50 ms, 5.10 ms, 4.89 ms) and a final summary: '4 packets transmitted, 4 received, 0% packet loss, time 3018ms rtt min/avg/max/mdev = 4.496/5.299/6.715/0.845 ms'. The terminal window has a dark background with a 'KALI' logo watermark. The top of the window shows the title bar 'kali@kali -' and system icons on the right.

```
(kali@kali)-[~]  
$ ping 192.168.1.35  
PING 192.168.1.35 (192.168.1.35) 56(84) bytes of data.  
64 bytes from 192.168.1.35: icmp_seq=1 ttl=64 time=6.72 ms  
64 bytes from 192.168.1.35: icmp_seq=2 ttl=64 time=4.50 ms  
64 bytes from 192.168.1.35: icmp_seq=3 ttl=64 time=5.10 ms  
64 bytes from 192.168.1.35: icmp_seq=4 ttl=64 time=4.89 ms  
^C  
--- 192.168.1.35 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3018ms  
rtt min/avg/max/mdev = 4.496/5.299/6.715/0.845 ms  
(kali@kali)-[~]  
$
```

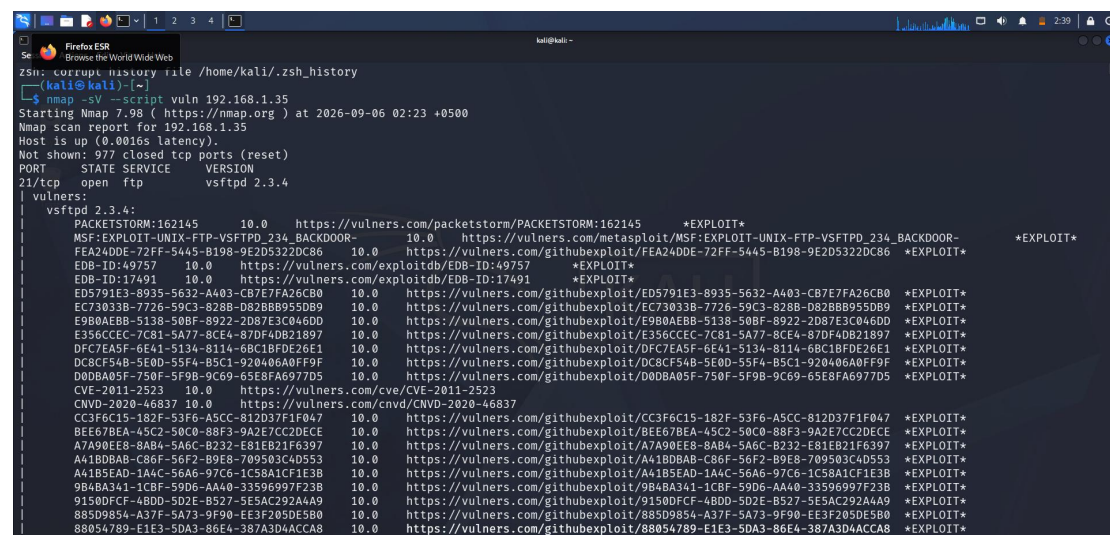
In the above figure **ping 192.168.1.35** was executed to check the target is reachable or not it is necessary to do before starting any security assessment.

Observed Result

IP Address:	192.168.1.35
Status:	Reachable
Packet sent:	4
Packet received:	4
Packet loss:	0
Average Response Time:	5.299 ms

Vulnerability Scanning using Nmap NSE Scripts

Command: **nmap -sV --script vuln 192.168.1.35**



```
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ nmap -sV --script vuln 192.168.1.35
Starting Nmap 7.90 ( https://nmap.org ) at 2026-09-06 02:23 +0500
Nmap scan report for 192.168.1.35
Host is up (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
vulners:
vsftpd 2.3.4:
PACKETSTORM:162145      10.0  https://vulners.com/packetstorm/PACKETSTORM:162145      *EXPLOIT*
MSF:EXPLOIT-UNIX-FTP-VSFTPD_234_BACKDOOR-      10.0  https://vulners.com/metasploit/MSF:EXPLOIT-UNIX-FTP-VSFTPD_234_BACKDOOR-      *EXPLOIT*
FEA24DDE-72FF-5445-B198-9E2D5322DC86      10.0  https://vulners.com/githubexploit/FEA24DDE-72FF-5445-B198-9E2D5322DC86      *EXPLOIT*
EDB-ID:49757      10.0  https://vulners.com/exploitdb/EDB-ID:49757      *EXPLOIT*
EDB-ID:17491      10.0  https://vulners.com/exploitdb/EDB-ID:17491      *EXPLOIT*
E05791E3-8935-5632-A403-C87E7FA26CB0      10.0  https://vulners.com/githubexploit/E05791E3-8935-5632-A403-C87E7FA26CB0      *EXPLOIT*
EC73033B-7726-59C3-828B-D82B8B9550B9      10.0  https://vulners.com/githubexploit/EC73033B-7726-59C3-828B-D82B8B9550B9      *EXPLOIT*
E9B0AEBB-5138-50BF-8922-2D87E3C046D0      10.0  https://vulners.com/githubexploit/E9B0AEBB-5138-50BF-8922-2D87E3C046D0      *EXPLOIT*
E356CCEC-7C81-5A77-8CE4-87DF4DB21897      10.0  https://vulners.com/githubexploit/E356CCEC-7C81-5A77-8CE4-87DF4DB21897      *EXPLOIT*
DFC7EA5F-6E41-5134-8114-68C1BFDE26E1      10.0  https://vulners.com/githubexploit/DFC7EA5F-6E41-5134-8114-68C1BFDE26E1      *EXPLOIT*
DC8CF54B-5E0D-55F4-B5C1-920406A0FF9F      10.0  https://vulners.com/githubexploit/DC8CF54B-5E0D-55F4-B5C1-920406A0FF9F      *EXPLOIT*
D0DBA05F-750F-5F9B-9C69-65E8FA6977D5      10.0  https://vulners.com/githubexploit/D0DBA05F-750F-5F9B-9C69-65E8FA6977D5      *EXPLOIT*
CVE-2011-2523      10.0  https://vulners.com/cve/CVE-2011-2523
CNDV-2020-46837      10.0  https://vulners.com/cnvd/CNDV-2020-46837
CC3F6C15-182F-53F6-A5CC-812D37F1F047      10.0  https://vulners.com/githubexploit/CC3F6C15-182F-53F6-A5CC-812D37F1F047      *EXPLOIT*
BEE678EA-45C2-50C0-88F3-9A2E7CC2DECE      10.0  https://vulners.com/githubexploit/BEE678EA-45C2-50C0-88F3-9A2E7CC2DECE      *EXPLOIT*
A7A90EE8-8AB4-5A6C-B232-E81EB21F6397      10.0  https://vulners.com/githubexploit/A7A90EE8-8AB4-5A6C-B232-E81EB21F6397      *EXPLOIT*
A418DBAB-C86F-56F2-B9E8-709503C4D553      10.0  https://vulners.com/githubexploit/A418DBAB-C86F-56F2-B9E8-709503C4D553      *EXPLOIT*
A41B5EAD-1A4C-56A6-97C6-1C58A1CF1E3B      10.0  https://vulners.com/githubexploit/A41B5EAD-1A4C-56A6-97C6-1C58A1CF1E3B      *EXPLOIT*
9B4BA341-1CBF-59D6-AA40-33596997F23B      10.0  https://vulners.com/githubexploit/9B4BA341-1CBF-59D6-AA40-33596997F23B      *EXPLOIT*
91500FF-4BDD-5D2E-B527-5E5AC292A4A9      10.0  https://vulners.com/githubexploit/91500FF-4BDD-5D2E-B527-5E5AC292A4A9      *EXPLOIT*
885D9B54-A37F-5A73-9F90-E3F2020E5B00      10.0  https://vulners.com/githubexploit/885D9B54-A37F-5A73-9F90-E3F2020E5B00      *EXPLOIT*
88054789-E1E3-5DA3-86E4-387A3D4ACCA8      10.0  https://vulners.com/githubexploit/88054789-E1E3-5DA3-86E4-387A3D4ACCA8      *EXPLOIT*
```

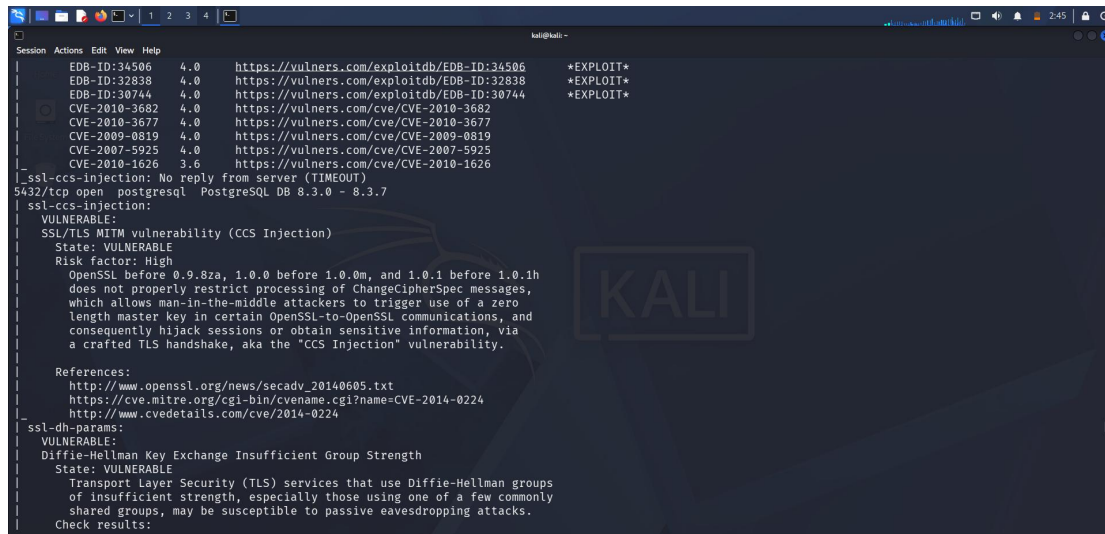
In the above Figure ftp vulnerability found with version vsftpd 2.3.4 there is backdoor vulnerability and the CVE (**Common vulnerability exposure**) for reference is CVE-2011-2523.

CVE Explanation for FTP

A backdoored archive release of **vsFTPd** version 2.3.4 was uploaded to the distribution site. When a client connects to port 21 and attempts to log in with a username ending in a smiley face :), the daemon triggers a malicious function that opens an unauthenticated command shell listener on port 6200/tcp.

Impact: Allows an attacker to achieve full root-level Remote Code Execution (RCE) on the underlying operating system.

Remediation: Allows an attacker to achieve full root-level Remote Code Execution (RCE) on the underlying operating system.



```
Session Actions Edit View Help
EDB-ID:34506 4.0 https://vulners.com/exploitdb/EDB-ID:34506 *EXPLOIT*
EDB-ID:32838 4.0 https://vulners.com/exploitdb/EDB-ID:32838 *EXPLOIT*
EDB-ID:30744 4.0 https://vulners.com/exploitdb/EDB-ID:30744 *EXPLOIT*
CVE-2010-3682 4.0 https://vulners.com/cve/CVE-2010-3682
CVE-2010-3677 4.0 https://vulners.com/cve/CVE-2010-3677
CVE-2009-0819 4.0 https://vulners.com/cve/CVE-2009-0819
CVE-2007-5925 4.0 https://vulners.com/cve/CVE-2007-5925
CVE-2010-1626 3.6 https://vulners.com/cve/CVE-2010-1626
ssl-ccs-injection: No reply from server (TIMEOUT)
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
ssl-ccs-injection:
VULNERABLE:
SSL/TLS MITM vulnerability (CCS Injection)
State: VULNERABLE
Risk factor: High
OpenSSL before 0.9.8za, 1.0.0m, and 1.0.1 before 1.0.1h
does not properly restrict processing of ChangeCipherSpec messages,
which allows man-in-the-middle attackers to trigger use of a zero
length master key in certain OpenSSL-to-OpenSSL communications, and
consequently hijack sessions or obtain sensitive information, via
a crafted TLS handshake, aka the "CCS Injection" vulnerability.
References:
http://www.openssl.org/news/secadv_20140605.txt
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
http://www.cvedetails.com/cve/2014-0224
ssl-dh-params:
VULNERABLE:
Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman groups
of insufficient strength, especially those using one of a few commonly
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
```

In the above Figure vulnerability scan results for the PostgreSQL service running on port 5432/tcp, highlighting two core SSL/TLS vulnerabilities. The first is the **SSL/TLS MITM Vulnerability (CCS Injection)** under reference **CVE-2014-0224**, where OpenSSL versions prior to 0.9.8za, 1.0.0m, and 1.0.1h fail to properly restrict ChangeCipherSpec messages during handshakes. The second is the **Diffie-Hellman Key Exchange Insufficient Group Strength** vulnerability, where the TLS service uses Diffie-Hellman parameters with weak group strength during key exchanges.

CVE Explanation of SSL/TLS MITM Vulnerability (CCS Injection)

OpenSSL versions prior to 0.9.8za, 1.0.0m, and 1.0.1h fail to properly restrict the processing of ChangeCipherSpec (CCS) messages during a TLS handshake. An attacker positioned in a Man-in-the-Middle (MITM) role can inject a prematurely sent ChangeCipherSpec packet in both directions before key generation is complete.

CVE Explanation of Diffie-Hellman Key Exchange Insufficient Group Strength

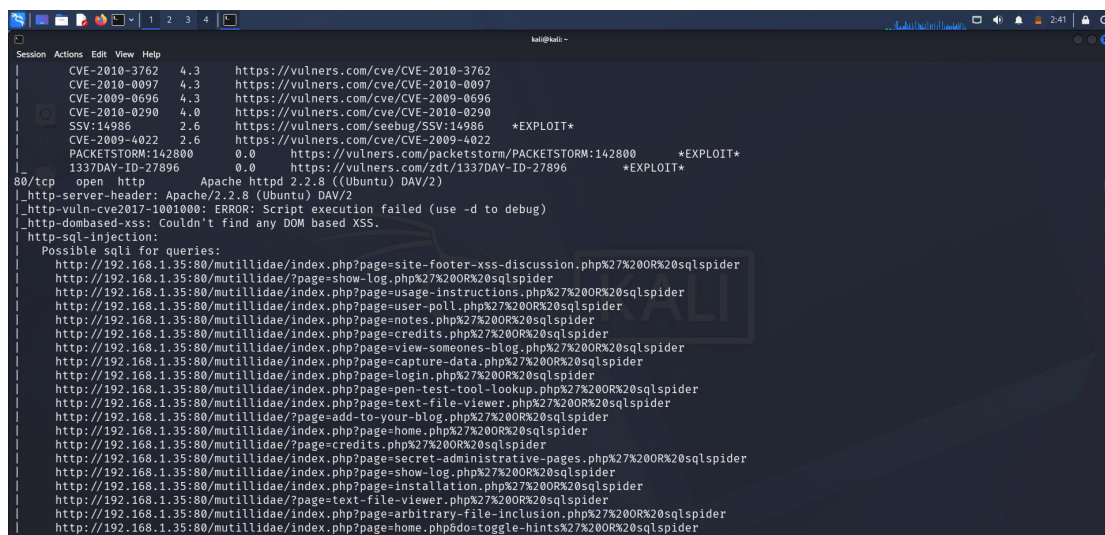
The PostgreSQL TLS service relies on Ephemeral Diffie-Hellman (DHE) key exchange cipher suites configured with legacy or weak prime groups (typically < 2048 bits, such as 512-bit or 1024-bit primes). In Diffie-Hellman handshakes, the group size dictates the computational effort required to solve the Discrete Logarithm Problem (DLP), which protects the generated session keys.

Impact

- A network attacker positioning themselves between the client application and the PostgreSQL database can force the handshake to use weak keying material.
- Allows attackers to decrypt, intercept, and modify sensitive database traffic—such as queries, credentials, and returned records—in real time without triggering handshake alerts.
- The use of legacy Diffie-Hellman (DH) parameters (typically \$< 2048\$ bits, such as 512-bit or 1024-bit prime groups) makes the key exchange susceptible to pre-computation attacks (e.g., Logjam).
- Attackers with sufficient computational power or network capture access can break the ephemeral session keys, compromising the confidentiality and forward secrecy of the TLS connection.

Remediation:

- **Upgrade OpenSSL Libraries:** Update the underlying OpenSSL package on both the PostgreSQL database server and connecting client systems to a patched release (or modern OpenSSL 1.1.1/3.x releases).
- **Apply OS Security Patches:** Run package manager updates and restart the PostgreSQL service to bind to the updated library.
- Generate custom 2048-bit or 4096-bit DH parameter files using OpenSSL.
- Point PostgreSQL to the updated parameter file in postgresql.conf and restart the service.



```
Session Actions Edit View Help
CVE-2010-3762 4.3 https://vulners.com/cve/CVE-2010-3762
CVE-2010-0097 4.3 https://vulners.com/cve/CVE-2010-0097
CVE-2009-0696 4.3 https://vulners.com/cve/CVE-2009-0696
CVE-2010-0290 4.0 https://vulners.com/cve/CVE-2010-0290
SSV:14986 2.6 https://vulners.com/seebug/SSV:14986 *EXPLOIT*
CVE-2009-4022 2.6 https://vulners.com/cve/CVE-2009-4022
PACKETSTORM:142800 0.0 https://vulners.com/packetstorm/PACKETSTORM:142800 *EXPLOIT*
1337DAY-ID-27896 0.0 https://vulners.com/zdt/1337DAY-ID-27896 *EXPLOIT*
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
_http-dombased-xss: couldn't find any DOM based XSS.
_http-sql-injection:
Possible sql injection:
http://192.168.1.35:80/mutillidae/index.php?page=site-footer-xss-discussion.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=usage-instructions.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=notes.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=capture-data.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/?page=credits.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=show-log.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=installation.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%20OR%20sqlspider
http://192.168.1.35:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
```

In the above Figure, the vulnerability scan results correspond to an HTTP service running on **port 80/tcp** served by **Apache httpd 2.2.8 ((Ubuntu) DAV/2)**. The Nmap script output highlights potential **SQL Injection (http-sql-injection)** vulnerabilities, where user-supplied parameters in queries are exposed to payload injection. Additionally, upper sections of the scan reveal CVE reference (e.g., CVE-2010-3762) and exploit availability indications for the target environment.

CVE Explanation for Apache web server

The target is running **Apache httpd version 2.2.8**, an unpatched legacy web server version containing multiple publicly known vulnerabilities. CVE-2010-3762 allows remote attackers to cause a denial-of-service (DoS) or potentially execute arbitrary code due to memory corruption issues in handling specific HTTP requests. The scan output explicitly confirms public exploit availability for this component.

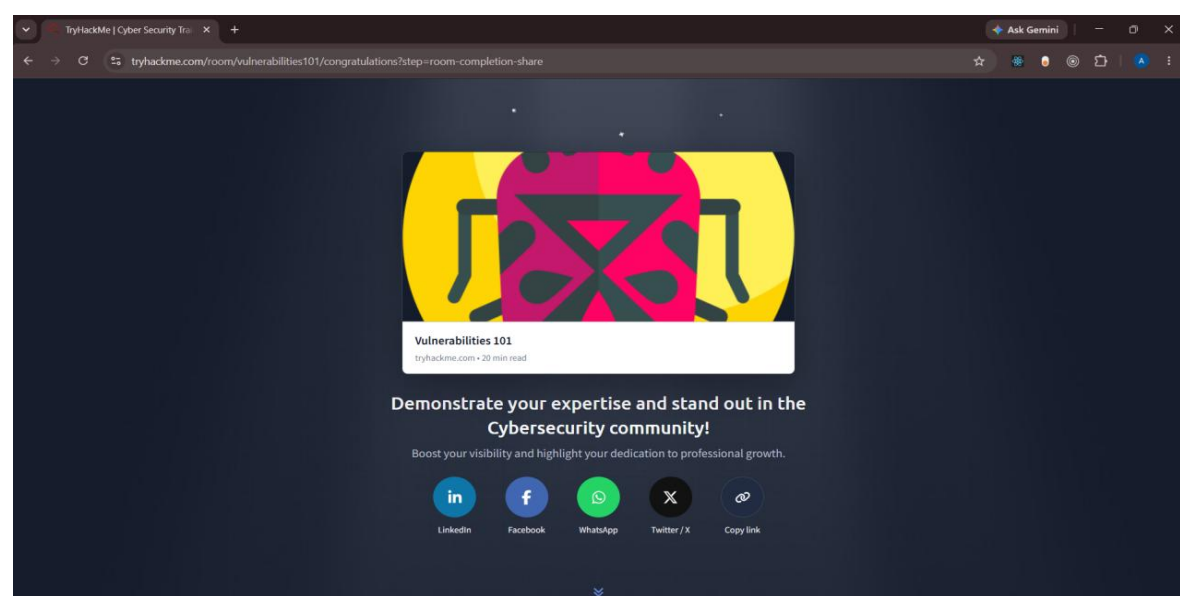
Impact: Unauthenticated remote code execution or complete service disruption.

Remediation: Upgrade the Apache HTTP Server to the latest stable release (or modern Apache2 package) and apply OS security patches.

List of Vulnerabilities

Service	Version	Vulnerability	CVE	Severity
FTP	vsFTPD 2.3.4	Unauthenticated Backdoor Command Execution	CVE-2011-2523	Critical (9.8)
PostgresQL	9.x / 10.x (OpenSSL backend)	SSL/TLS MITM Vulnerability (CCS Injection)	CVE-2014-0224	High (7.4)
PostgresQL	Any (with DHE cipher suite)	Diffie-Hellman Insufficient Group Strength	CVE2015-4000	High / Medium
Apache	httpd 2.2.8	Remote Code Execution	CVE-2010-3762	High

TryHackme Room Vulnerability 101



The screenshot shows a web browser window with the URL `tryhackme.com/room/vulnerabilities101/congratulations/step~room-completion-share`. The page features a large, stylized graphic of a red and yellow bug with a black 'X' on its back. Below the graphic, the text reads "Vulnerabilities 101" and "tryhackme.com • 20 min read". The main message on the page is "Demonstrate your expertise and stand out in the Cybersecurity community!" followed by "Boost your visibility and highlight your dedication to professional growth." At the bottom, there are five circular icons for social media sharing: LinkedIn, Facebook, WhatsApp, Twitter / X, and a "Copy link" button.

The Vulnerability 101 room was successfully completed this room help me to understand about the vulnerabilities and common vulnerabilities and exposures (CVE), vulnerabilities database like exploit db search-sploit , how vulnerabilities are scored Common vulnerability scoring system (CVSS) and Vulnerability Priority Rating (VPR) and a practical example means I practiced that how to find a vulnerability in an application.

Conclusion

This task covered the full assessment lifecycle: reconnaissance, enumeration, vulnerability identification, research, exploitation, and flag capture. The lab showed how outdated software and missing patches can result in unauthorized access. It gave me hands-on experience with a complete pen-testing workflow and helped me understand how security professionals detect, analyze, and exploit vulnerabilities in a safe environment. The exercise also emphasized why regular security testing, vulnerability management, and prompt patching are critical to defend against real-world cyber threats.